

第二讲 信息系统安全概述

信息系统为什么会有安全问题？

内部原因：信息系统自身存在脆弱性；

外部原因：信息系统面临着来自外部的各种威胁。

一、信息系统面临的安全威胁

信息系统安全威胁（threat）是指对于信息系统的组成要素及其功能造成某种损害的潜在可能。

攻击所具有的固有危害程度——攻击致命度（AL）

攻击分类与致命度

分类	描述	AL
Root	获取管理员权限	10
User	获取普通用户权限	5
Data	非授权访问或读写数据	3
DoS	拒绝服务攻击	2
Probe	扫描攻击	0.5
Other	其他	*

二、信息系统的脆弱性

信息资产及其安全措施在安全方面的不足和弱点。脆弱性也常常被称为漏洞。

1、信息系统脆弱性的表现

（1）硬件组件

信息系统硬件组件的安全隐患多来源于设计，主要表现为物理安全方面的问题。

（2）软件组件

软件组件的安全隐患来源于设计和软件工程中的问题。

➤ 漏洞

- 不必要的功能冗余引起安全脆弱性；
- 未按安全等级要求进行模块化设计，安全等级不能达到预期

(3) 网络和通信协议

- TCP/IP 协议族本身的缺陷
- 基于 TCP/IP 协议 Internet 的安全隐患
 - 缺乏对用户身份的鉴别
 - 缺乏对路由协议的鉴别认证
 - TCP/UDP 的缺陷

2、硬件安全：“小荷才露尖尖角”

恶意攻击者在计算机的处理器芯片中植入后门，这种基于“硅元素”的后门很难被发现。计算机芯片中有着数以亿计的元件，如果想要找出这样的一种单一组件（后门程序），可以算得上是大海捞针了。

让问题更加严重的就是，计算机芯片中的每一个组件其大小甚至都不到人类头发丝直径的千分之一。

攻击者可以利用微处理器来执行一系列看似合法的指令，然后触发处理器芯片中的某些功能，以此来获取到目标主机的操作系统访问权限。

3、软件安全：“剪不断，理还乱”

- (1) 软件缺陷普遍存在
- (2) 软件系统的复杂性

4、协议安全：“旧仇未了，又添新恨”

(1) 发现和证实 TCP/IP 协议栈安全漏洞是从未知到已知的科学证伪过程

(2) 工业网络协议

5、攻防不对称：“5G 究竟是一股清流，还是火上浇油”）

(1) 攻防不对称性



(2) 信息系统安全是个时间的概念

安全=及时的检测和处理

新的安全定义：■及时的检测就是安全■及时的响应就是安全

防护时间 P_t ：黑客在到达攻击目标之前需要攻破很多的设备

（路由器，交换机）、系统（NT，UNIX）和防火墙等障碍，在黑客达到目标之前的时间；

D_t ：在黑客攻击过程中，我们检测到他的活动的所用时间；

R_t ：检测到黑客的行为后，我们需要作出响应的这段时间。

假如能做到 $Dt + Rt < Pt$ ，那么我们可以说我们的目标系统是安全的。

如果 $Pt \leq Dt + Rt$ ，那么暴露时间 $Et = (Dt + Rt - Pt)$ 。

(3) Unbalance incurred by 5G

- 网络是个整体，攻击可以从任何一个薄弱点发起
- 网络攻击已自动化和智能化
- 安全响应速度要求越来越快，但面对海量安全事件，人力无法及时有效地分析处理

三、实现信息系统安全的方法一——基于保障的信息系统安全

1、基于信息保障的信息系统安全概念

信息系统安全保障是在信息系统的**整个生命周期**中，通过对信息系统的**风险分析**，制定并执行相应的安全保障策略，从**技术、管理、工程和人员**等方面提出安全保障要求，确保信息系统的**保密性、完整性和可用性**，降低安全风险到可接受的程度，从而保障系统实现**组织机构的使命**。

2、信息系统安全的目标

信息系统安全保障的目的不仅是保护信息和资产的安全，更重要的是通过保障信息系统的安全来保障信息系统所支持的业务的安全，从而达到实现企业使命的目的。

进不来->拿不走->看不懂->改不了->跑不了

3、信息系统安全保障模型

(1) CMM 框架

信息系统安全保障模型——CMM框架

在安全技术上，不仅要考虑具体的产品和技术，更要考虑信息系统的安全技术体系架构。

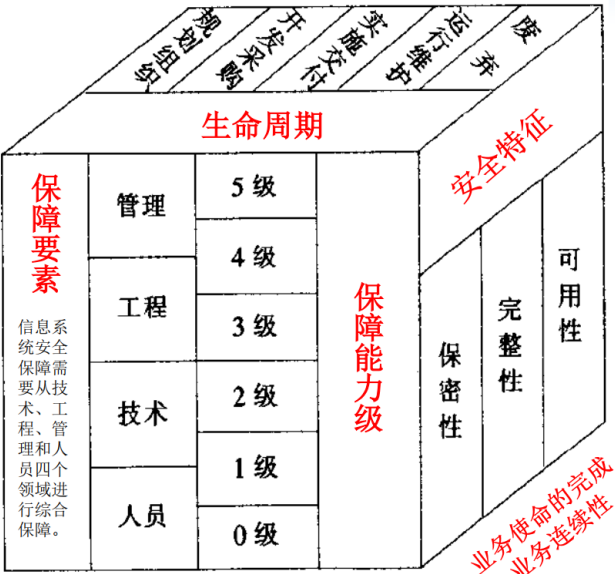
建立相应的安全保障管理体系，形成长效和持续改进的安全管理机制。

安全工程上要注重工程过程各个阶段的规范化实施。

注重人的安全意识以及安全专业技能和能力等。

安全保障能力维

- 第一能力级别0：未实施；
- 第二能力级别1：基本执行；
- 第三能力级别2：计划跟踪；
- 第四能力级别3：充分定义；
- 第五能力级别4：量化控制；
- 第六能力级别5：持续改进。



由合格的信息安全专业人员，使用合格的信息安全技术和产品，通过规范、可持续性改进的工程过程能力和管理能力进行建设和运行维护，达到安全保障的信息系统。

信息安全保障是一种立体保障

《GB/T 20274.1-2006 信息安全技术 信息系统安全保障评估框架 第一部分：简介和一般模型》

(2) DSMM (Data Security capability Maturity Model)

DSMM 认证是我国首个依据国家标准《信息安全技术 数据安全能力成熟度模型》(GB/T 37988-2019)、《数据安全能力建设实施指南 v1.0》开展的数据安全认证，该标准是由阿里巴巴联合中国电子技术标准化研究院、国家信息安全工程技术研究中心、中国信息安全测评中心等业内权威机构联合编写的国家标准，是国内第一个数据安全标准认证，于 2019 年 8 月 30 日发布，2020 年 3 月 1 日正式实施。

DSMM 评估以组织为单位，以数据为中心，围绕四个安全能力维度、七个安全过程维度、五个安全能力等级评价组织的数据安全能力。

DSMM 标准能够用来衡量一个组织的数据安全能力成熟度水平，可以帮助行业、企业和组织发现数据安全能力短板，相关主管部门也可以用于数据安全的管理，根据数据安全能力水平高低决定企业拥有数据的类型和范围，最终提升全社会的数据安全水平和行业竞争力，确保大数据产业及数字经济的发展。



4、信息系统安全的理解

信息网络的硬件、软件及其系统中的数据受到保护，不受偶然的或者恶意的原因而遭到破坏、更改、泄露，系统连续可靠正常地运行，信息服务不中断。

5、信息系统安全保障标准

- 《GB/T 31495.1-2015 信息安全技术 信息安全保障指标体系及评价方法 第1部分：概念和模型》

• 《GB/T 31495.2-2015 信息安全技术 信息安全保障指标体系及评价方法 第2部分：指标体系》

• 《GB/T 31495.3-2015 信息安全技术 信息安全保障指标体系及评价方法 第3部分：实施指南》

四、信息系统安全架构设计（以云计算为例）

1、等级保护 2.0 “6.2 云计算安全扩展要求”

6.2.1 安全物理环境

6.2.1.1 基础设施位置 应保证云计算基础设施位于中国境内。

6.2.2 安全通信网络

6.2.2.1 网络架构

本项要求包括：

- a) 应保证云计算平台不承载高于其安全保护等级的业务应用系统；
- b) 应实现不同云服务客户虚拟网络之间的隔离。

6.2.3 安全区域边界

6.2.3.1 访问控制

应在虚拟化网络边界部署访问控制机制，并设置访问控制规则。

6.2.4 安全计算环境

6.2.4.1 访问控制

本项要求包括：

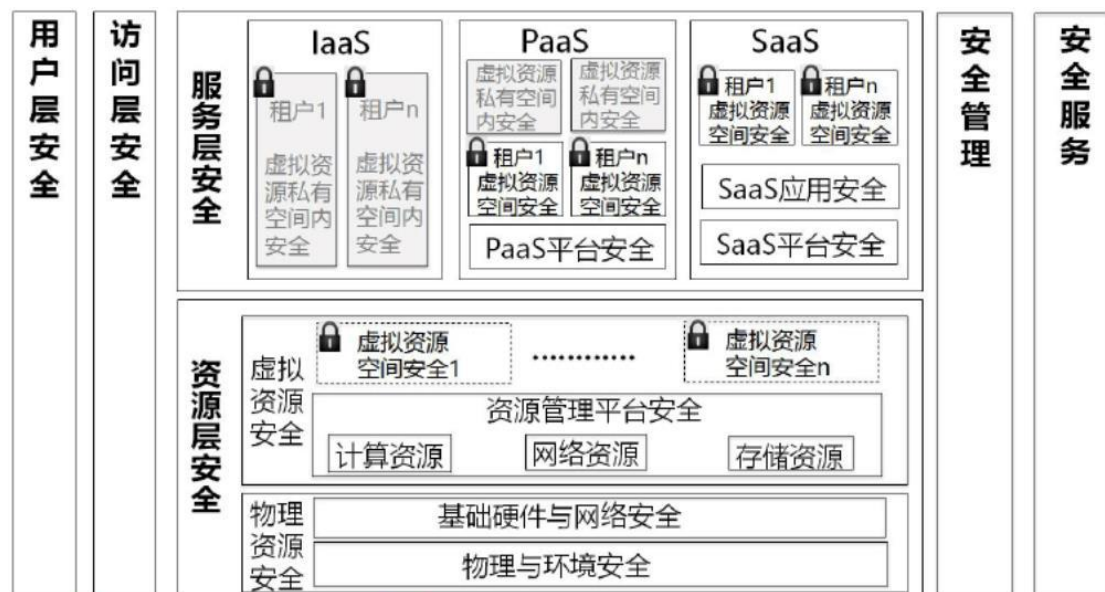
- a) 应保证当虚拟机迁移时，访问控制策略随其迁移；
- b) 应允许云服务客户设置不同虚拟机之间的访问控制策略。

6.2.4.2 数据完整性和保密性

应确保云服务客户数据、用户个人信息等存储于中国境内，如需出境应遵循国家相关规定。

6.2.5 安全建设管理

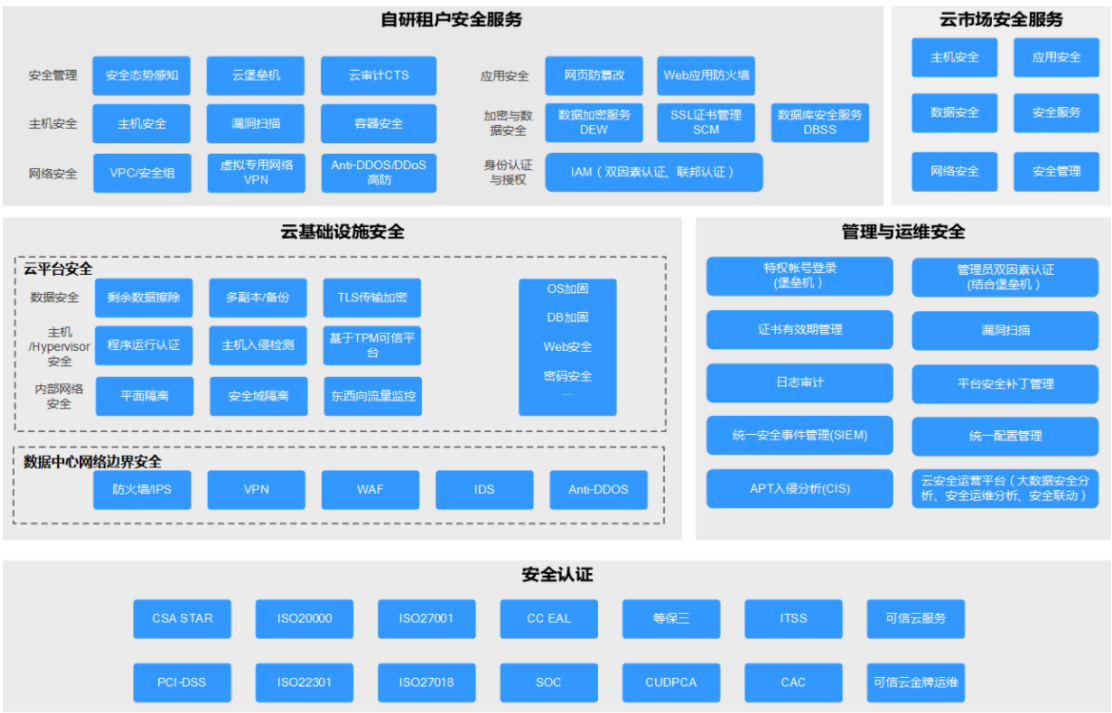
2、云计算安全技术要求框架



3、腾讯云安全防护体系架构



4、华为云安全体系架构



5、云计算安全架构的最新发展（了解）

- (1) 基于可信根的安全架构
- (2) 基于隔离的安全架构
- (3) 安全即服务的安全架构

(4) 可管、可控、可度量的云计算安全架构

五、拟态主动防御（应对攻防不对称性）

拟态 (mimicry)，是自然界中一种生物伪装成另一种生物，或伪装成环境中其它物体以获取生存优势的能力。

这也是网络空间拟态防御 (Cyber Mimic Defense, CMD) 思想的起源。